

Trafico de red, poisoning y relay

Objetivos de aprendizaje

Identificar la superficie, explicar la causa, diseñar una confirmación mínima, interpretar evidencia y proponer una mitigación causal.

Prerrequisitos

Flujo source-transformación-validación-sink, parsers, permisos y metodología de hipótesis. Revisa los prerrequisitos declarados en los metadatos.

Fundamentos técnicos

Observar trafico describe protocolos y flujos; poisoning responde a resoluciones inseguras para provocar autenticacion; relay reenvia esa autenticacion a otro servicio. Son niveles de intervencion y riesgo diferentes.

LLMNR/NBT-NS y NTLM pueden exponer hashes NetNTLM o permitir relay cuando la firma SMB no es obligatoria. La segmentacion y los controles de firma determinan si el ataque atraviesa la red.

Modelo mental

Entrada controlada -> transformaciones -> validación -> componente final
-> sink -> efecto observable -> decisión

El paso crítico es demostrar qué componente consume el valor y con qué identidad o privilegios.

Superficie de ataque

En un segmento de laboratorio donde aparecen broadcasts de resolucion, autenticacion NTLM y objetivos con SMB signing desactivado.

Cómo identificarla

- LLMNR
- NBT-NS
- NetNTLMv2
- SMB signing disabled
- Broadcast
- Segmentacion

Preguntas que debo hacerme

- ¿Qué dato controlo exactamente y en qué formato viaja?
- ¿Qué transformaciones y normalizaciones ocurren antes del sink?
- ¿Qué identidad ejecuta la operación y qué permisos tiene?
- ¿Qué otra explicación produciría la misma señal?
- ¿Cuál es la prueba de menor riesgo que separa ambas explicaciones?

Prueba mínima

Separa evidencia pasiva, hash capturado y autenticacion reenviada; no presentes una captura como si ya implicara ejecucion.

Evidencia esperada: Sabes si existe solo exposicion de credenciales, posibilidad de crackeo offline o una ruta de relay con impacto lateral.

Construcción progresiva del payload

1. Reproduce una entrada válida.
2. Aísla un único valor controlable.
3. Define la primitiva mínima indicada por la fuente.
4. Predice resultado y control negativo.
5. Aplica una sola adaptación cuando haya evidencia de restricción.
6. Confirma de forma reproducible antes de ampliar impacto.

Capa 1: prueba documentada

```
sudo responder -I tun0 -wv
```

Objetivo y contexto: Escucha y responde en la interfaz autorizada para capturar autenticación de laboratorio.

Resultado esperado: Hash NetNTLMv2 con usuario y host de origen.

Capa 2: prueba documentada

```
impacket-ntlmrelayx -tf targets.txt -smb2support
```

Objetivo y contexto: Prueba relay solo contra objetivos previamente validados sin firma SMB obligatoria.

Resultado esperado: Autenticación aceptada o rechazo que confirma el control defensivo.

Anatomía de los payloads

La primera prueba es `sudo responder -I tun0 -wv`. Separa sus delimitadores, operadores, opciones, operandos y variables; algunos elementos no estarán presentes según el contexto. Las comillas, barras y separadores pertenecen a una capa concreta. Usa la explicación de cada capa para determinar qué símbolo altera sintaxis y cuál transporta datos.

Variaciones según el contexto

No traslades una prueba entre sistemas operativos, motores, frameworks o versiones sin revisar sintaxis y comportamiento. Conserva la primitiva y vuelve a serializarla para el parser real.

Filtros y bypasses

No existe un bypass universal. Registra la forma enviada, la forma decodificada, la comparación, la normalización y la forma consumida. Una adaptación es válida solo si demuestra una discrepancia concreta; si la validación ocurre sobre la forma canónica y expresa la propiedad correcta, la variante no debe funcionar.

Evidencias de confirmación

Sabes si existe solo exposición de credenciales, posibilidad de crackeo offline o una ruta de relay con impacto lateral.

Usa además una entrada inocua y un control negativo. No confundas reflexión, error genérico o demora aislada con confirmación.

Escalado de impacto

- Identifica interfaz y alcance.
- Observa antes de responder.
- Captura una autenticación de laboratorio.
- Comprueba signing en objetivos.
- Solo entonces evalúa relay y documenta impacto.

Amplía únicamente dentro del laboratorio y cuando cada salto aporte una capacidad nueva demostrable.

Errores frecuentes

- No estas en el mismo segmento ni tienes un pivot con visibilidad del broadcast.
- SMB signing es obligatorio en los objetivos de relay.
- El alcance no autoriza poisoning o manipulacion de trafico.
- Ejecutar la prueba sin adaptar variables ni versión.
- Cambiar varias capas a la vez.
- Omitir el control negativo o no guardar evidencia.

Diagnóstico de payloads fallidos

Síntoma	Posible causa	Prueba de diagnóstico	Adaptación
Rechazo inmediato	Formato o precondition	Repetir entrada válida	Corregir transporte
Sin diferencia	Entrada ignorada o canal ciego	Marcador y control negativo	Buscar evidencia adecuada
Error del componente	Contexto o versión	Reducir a prueba mínima	Consultar manual detectado
Resultado parcial	Permisos/restricción	Comprobar identidad y alcance	Reducir primitiva

Mitigaciones

Eliminar el dato controlable del sink cuando sea posible; usar APIs estructuradas, allowlists sobre valores canónicos, privilegio mínimo, autorización en servidor y registros que permitan detectar abuso. La defensa concreta debe impedir la causa explicada en Fundamentos técnicos.

Relación con pentesting y certificaciones

Se espera reconocer la señal, justificar la prueba elegida, adaptar variables, interpretar salida y documentar impacto y mitigación. La puntuación debe premiar razonamiento y evidencia, no memoria literal.

Caso guiado

Parte de una señal de la lista anterior. Escribe observación e hipótesis, ejecuta la prueba mínima, compara con el control y clasifica el resultado como no confirmado, indicio o confirmación. Solo entonces sigue los pasos de escalado relevantes.

Caso de adaptación

Si la prueba básica falla, no cambies caracteres al azar. Comprueba primero transporte, parser, versión, permisos y canal de evidencia. Diseña una segunda prueba que discrimine entre las dos causas más probables.

Ejercicios

1. Señala source, transformaciones y sink en el caso guiado.
2. Explica qué evidencia refutaría la hipótesis.
3. Descompón la primera prueba documentada por opciones y argumentos.
4. Propón un control negativo y una mitigación causal.

Resumen

Distinguir observacion pasiva, captura de autenticacion y relay activo dentro del mismo segmento. La técnica queda confirmada solo cuando una prueba mínima produce la evidencia prevista y descarta explicaciones alternativas.

Chuleta operativa

1. Confirmar alcance y precondiciones.
2. Identificar entrada, componente y permisos.
3. Ejecutar prueba mínima y control.
4. Interpretar señal antes de escalar.
5. Guardar evidencia y mitigación.

Referencias

- [Concepto fuente de THM Fieldbook \(network-traffic-mitm\)](#)
- [Referencia técnica externa](#)

Navegación

Anterior: [Construcción de payloads](#). Índice: [curso](#). Ejercicios y chuleta se enlazarán desde la matriz de trazabilidad.